

SECCIÓN 3.1



Cómo se ve la actividad de red en un SOC

Temas de esta sección:

- Por qué un analista SOC necesita entender redes
- La actividad de red como evidencia: fuentes disponibles
- Qué datos aparecen en un evento de red
- Origen, destino, puerto, protocolo y acción del control
- Volumen, frecuencia y duración como señales
- Tráfico normal, anómalo y sospechoso
- La importancia del proceso asociado a una conexión
- Comunicación interna vs externa · Correlación de eventos

3.1 | Por qué un analista SOC necesita entender redes



En un SOC, muchas alertas no aparecen como 'malware detectado'. Lo que solemos ver es mucho más básico:

- Una conexión hacia una IP externa

- Un equipo comunicándose con muchos hosts internos

- Un puerto abierto

- Un volumen de tráfico fuera de lo normal

- Una consulta DNS

- Un proceso generando tráfico inusual

- Un intento de conexión bloqueado

- Una conexión repetitiva cada cierta cantidad de segundos

No hace falta ser administrador de redes para trabajar como SOC Level 1, pero sí es necesario **poder leer eventos de red, entender qué datos importan y saber qué preguntas hacerse.**

3.1 | Qué datos aparecen en un evento de red



Un evento de red típico puede incluir:

```
Timestamp: 2026-05-10 14:32:11
Source IP: 10.20.15.44
Source Host: USER-LAP-044
Source User: jperez
Destination IP: 185.22.10.90
Destination Domain: update-service-check.com
Destination Port: 443
Protocol: TCP
Action: Allowed
Bytes Sent: 1.2 MB
Bytes Received: 45 KB
Process: powershell.exe
```

▸ Qué equipo inició la conexión

▸ Qué usuario estaba asociado

▸ Hacia dónde se conectó

▸ Qué puerto usó y si fue permitido

▸ Cuánto volumen de datos hubo

▸ Qué proceso generó la comunicación

El análisis no se basa en un solo campo, sino en la combinación de todos.



Tres campos clave que orientan (pero no determinan) el análisis:

Puertos comunes:

80 → HTTP
53 → DNS
3389 → RDP
25 → SMTP

443 → HTTPS
445 → SMB
22 → SSH
123 → NTP

Acciones del control:

Allowed	Conexión permitida
Blocked	Conexión bloqueada
Denied	Acceso denegado
Logged	Solo registrado
Quarantined	Archivo en cuarentena

⚠ **El puerto orienta, pero el contexto decide.** Puerto 443 puede ser HTTPS legítimo o puede ser usado por malware para ocultar comunicación. Puerto 445 puede ser administración o movimiento lateral. Bloqueado no significa caso cerrado.

3.1 | Volumen, frecuencia y duración



En red, el comportamiento muchas veces importa más que un dato aislado. Tres elementos clave:

VOLUMEN	Cuántos datos se enviaron o recibieron.	<i>Ej: Una subida de 4 GB puede ser backup legítimo, sincronización o posible exfiltración.</i>
FRECUENCIA	Cada cuánto ocurre la comunicación.	<i>Ej: Una conexión cada 30 segundos al mismo dominio puede ser actividad automatizada o posible beaconing.</i>
DURACIÓN	Cuánto tiempo dura la conexión o sesión.	<i>Ej: Una sesión VPN de 6 horas a las 3 AM desde un host desconocido requiere revisión.</i>

El analista debe mirar patrones, no solo eventos sueltos.



No todo lo anómalo es malicioso. Y no todo lo normal es seguro.

NORMAL	Actividad esperada para ese usuario, sistema o aplicación.	<i>Ejemplo: Un navegador accediendo a sitios corporativos durante horario laboral.</i>
ANÓMALO	Actividad que se sale del patrón habitual, pero no necesariamente maliciosa.	<i>Ejemplo: Un usuario descargando más datos de lo habitual porque está preparando una auditoría.</i>
SOSPECHOSO	Actividad con señales compatibles con abuso, compromiso o técnica de ataque.	<i>Ejemplo: Un ejecutable en AppData conectándose cada minuto a un dominio externo desconocido.</i>

El trabajo del SOC es diferenciar estas categorías con evidencia y contexto.



Una de las preguntas más importantes en análisis de red:

¿Qué proceso generó esta conexión?

<code>chrome.exe → conexión HTTPS</code>	Bajo riesgo	El mismo destino puede tener distinta interpretación según el proceso. El mismo proceso puede ser legítimo o sospechoso según: ▸ Proceso padre ▸ Línea de comandos ▸ Ruta de ejecución ▸ Usuario ▸ Firma del archivo ▸ Horario ▸ Actividad previa y posterior
<code>powershell.exe → conexión HTTPS</code>	Requiere análisis	
<code>rundll32.exe → conexión externa</code>	Alta sospecha	
<code>unknown.exe desde AppData → conexión periódica</code>	Prioritario	

La red debe conectarse con el endpoint.

3.1 | Correlación: de eventos aislados a evidencia



Una conexión aislada dice poco. La secuencia cuenta la historia:

10 : 01	Usuario recibe correo con adjunto
10 : 03	WINWORD.EXE ejecuta powershell.exe
10 : 04	PowerShell consulta dominio update-check-file.com
10 : 04	PowerShell conecta por HTTPS al dominio
10 : 05	Se descarga archivo update.exe
10 : 06	update.exe se ejecuta desde AppData
10 : 07	Host inicia conexiones periódicas cada 60 segundos

Posible phishing → ejecución inicial → descarga de payload → persistencia y C2. La correlación convierte eventos de red y endpoint en evidencia útil.

3.1 | Errores comunes al analizar actividad de red



Errores frecuentes que reducen la calidad del análisis:

✗ Asumir que todo tráfico por 443 es legítimo

✓ 443 es el puerto de HTTPS, pero también lo usa malware para ocultar comunicación C2.

✗ No revisar qué proceso generó la conexión

✓ El proceso es el dato más discriminante. Sin él, el análisis es incompleto.

✗ Cerrar una alerta porque el firewall bloqueó

✓ El bloqueo reduce el impacto, pero no responde: ¿cómo llegó? ¿hay más afectados?

✗ Ignorar tráfico interno porque 'está dentro de la red'

✓ Tráfico interno puede ser movimiento lateral o reconocimiento post-compromiso.

✗ Analizar una IP sin revisar el dominio asociado

✓ La IP puede rotar; el dominio da contexto sobre la infraestructura.

✗ No mirar frecuencia, volumen y repetición

✓ Un patrón de beaconing no se ve en un solo evento; aparece en la serie temporal.